MODULE 23 · DOMAIN 8 - HCP TERRAFORM

HCP Terraform: Governance, Policy and Editions

Rules the configuration author cannot edit, and the three editions the exam expects you to tell apart.

DOMAIN 8 of 8 COURSE WEIGHT 12% MODULE 23 of 27

admin@sthithapragna.com

Governance is a rule **the person writing the configuration cannot remove**. That is the whole distinction.

What governance covers here

- **Policy as code**, evaluated against a plan before an apply is permitted.
- **Run tasks**, which call an external service at defined points in a run.
- **Cost estimation**, shown between plan and apply.
- **Drift detection and health assessments**, which watch infrastructure between runs.
- **Teams, permissions, SSO and audit logging**, which govern who may do what.

> ON THE EXAM
>
> Every item here depends on remote execution, as module twenty-one established. Local execution mode disables most of this list.

Sentinel

- **HashiCorp's own policy as code framework**, with its own language, used across their products.
- Policies are evaluated **against the plan**, so they see what would happen before it happens.
- Typical rules: **required tags, permitted instance sizes, forbidden regions, mandatory encryption**.
- Policies are grouped into **policy sets** and applied to workspaces or projects.
- **They run between plan and apply.** A failing policy stops the apply, it does not undo anything.

> ON THE EXAM
>
> Sentinel sees the plan, not the configuration. It judges the proposed change rather than the code that produced it.

Open Policy Agent

- **OPA is the open source alternative**, using the Rego language, and HCP Terraform supports it.
- Attractive when an organisation **already uses OPA elsewhere**, for Kubernetes or APIs.
- It evaluates the same thing: the **plan**, before an apply is allowed.
- The two are **alternatives, not layers**. You would not normally run both against one workspace.
- The exam expects you to know both exist and that both are supported.

> ON THE EXAM
>
> Sentinel is HashiCorp's; OPA is the open source option. Knowing that both are supported is usually enough.

The three enforcement levels

LEVEL	WHAT A FAILURE DOES
Advisory	Logs a warning. The run continues and the apply proceeds
Soft-mandatory	Stops the run, and someone with permission may override it
Hard-mandatory	Stops the run. Nobody can override it; the configuration must change

ON THE EXAM

This is the most reliably tested item in Domain 8. Advisory warns, soft-mandatory can be overridden, hard-mandatory cannot.

Choosing a level

- **Advisory** for a new rule you are still testing, or guidance that should not block anyone.
- **Soft-mandatory** where exceptions are legitimate but should be deliberate and recorded.
- **Hard-mandatory** for genuine absolutes: regulatory boundaries, encryption, forbidden regions.
- The override on soft-mandatory is **recorded**, so an exception leaves a trail.
- **Making everything hard-mandatory** tends to produce a queue at the policy team, not better compliance.

> ON THE EXAM
>
> The question to ask is whether an exception could ever be legitimate. If yes, soft-mandatory. If never, hard-mandatory.

Run tasks

- **An integration point that calls an external service** during a run, at a defined stage.
- Stages include before and after the plan, and before and after the apply.
- Typical uses: **security scanning, cost tooling, change management, compliance checks**.
- The task can **pass or fail the run**, so a third-party tool gains the same gate a policy has.
- **Not the same as policy as code.** A run task calls out; a policy is evaluated inside HCP Terraform.

> ON THE EXAM
>
> Run tasks are how tools HashiCorp does not make get a say in whether an apply proceeds.

Cost estimation

- **Estimates the cost of resources in a plan**, hourly and monthly, with the monthly delta.
- **Disabled by default.** It is enabled at the organisation level, for all workspaces at once.
- When enabled, it appears as **an extra run phase, between plan and apply**.
- It supports resources in the **three major cloud providers**, and not everything is estimable.
- Estimates can be **fed into policy**, so a change above a threshold fails a check.

> ON THE EXAM
>
> It is an estimate. Some resources have no cost data, and usage-based pricing cannot be predicted from a plan.

Drift detection and health assessments

- **HCP Terraform can check workspaces on a schedule**, without anyone running anything.
- **Drift detection** compares state against reality and reports differences. Module seventeen's comparison, managed.
- **Continuous validation** re-runs your **check blocks** on the same schedule. Module twelve.
- Together these are called **health assessments**, and results appear on the workspace.
- **Detection, not remediation.** Nothing is applied automatically; a human still decides.

> ON THE EXAM
>
> Module twelve said check blocks warn rather than block. Continuous validation is what makes that warning useful over time.

The private module registry, revisited

- Module fifteen covered publishing. Its governance value is **controlling what modules exist**.
- A curated registry means teams compose from **approved building blocks** rather than starting from raw resources.
- Combined with policy, you get **defaults from modules and limits from policy**.
- **No-code provisioning** lets people deploy from a module without writing configuration at all.
- Curation is not enforcement. A module can be ignored; a policy cannot.

> ON THE EXAM
>
> Modules make the right thing easy. Policy makes the wrong thing impossible. Most organisations need both.

Teams, permissions and identity

- **Organisations contain projects, workspaces and teams.** Permissions attach to teams, not individuals.
- Permissions are granular: **read, plan, write, admin**, and separately for variables and state.
- **Being able to plan and being able to apply are different permissions**, which is the point.
- **SSO** connects an existing identity provider, so leavers lose access automatically.
- **Audit logging** records who did what, which is what most compliance requirements actually ask for.

> ON THE EXAM
>
> Separating plan from apply is the permission model's central idea. Everyone can see the change; few can make it.

The three editions

EDITION	WHAT IT IS
Community	The free CLI you download and run yourself. No service, no UI, no policy
HCP Terraform	HashiCorp's managed SaaS, in tiers, with governance features
Terraform Enterprise	The same capabilities, self-hosted in your own infrastructure

ON THE EXAM

The exam's own description says a candidate can identify Terraform Enterprise features and distinguish them from Community edition.

HCP Terraform or Terraform Enterprise?

HCP TERRAFORM

HashiCorp runs it

- Nothing to install or operate
- Upgrades handled for you
- Your state lives in their service
- The usual choice unless something forbids it

TERRAFORM ENTERPRISE

You run it

- Installed in your own infrastructure
- Full control of data residency
- Works in an isolated network
- You own operations and upgrades

THE TIEBREAKER

The deciding factors are data residency, network isolation and regulatory constraint. Not feature availability.

What Community edition does not have

- **No run environment.** Runs happen wherever you type the command.
- **No policy as code, no run tasks, no cost estimation.** Those are service features.
- **No teams, permissions, SSO or audit logging.** Those come from the platform's identity model.
- **No managed state.** You configure and operate a backend yourself. Module sixteen.
- **The language and the CLI are identical.** Everything in domains one to seven applies unchanged.

> ON THE EXAM
>
> The distinction is a service, not a language. A question about a feature that requires a run environment is asking about the paid editions.

Reading the scenario

THE WORDING SAYS	IT IS POINTING AT
This must never be bypassed	Hard-mandatory enforcement
Exceptions with approval and a record	Soft-mandatory enforcement
Warn us but do not block anyone	Advisory enforcement, or a check block
Our security scanner must gate the apply	A run task, not a policy
Data must stay inside our own network	Terraform Enterprise, self-hosted
Tell us when a certificate is expiring	Continuous validation, on check blocks

ON THE EXAM

Ask whether the requirement is a rule, an integration, or an observation. Each maps to a different feature.

> A security team defines three rules. Resources must never be created in an unapproved region, because of a legal data residency requirement. Instances should normally be within an approved size list, though a documented exception is occasionally justified. And a naming convention should be encouraged but must not block anyone.
>
> They ask which enforcement level applies to each.

What is the correct mapping?

A All three hard-mandatory, since all three are organisation policy

B Region hard-mandatory, instance size soft-mandatory, naming advisory

C Region soft-mandatory, instance size advisory, naming hard-mandatory

D All three advisory, with a run task to enforce the region rule

◆ PAUSE AND DECIDE

What is the correct mapping?

A — All hard-mandatory

Ignores the language. 'Occasionally justified' and 'must not block anyone' both describe exceptions, which hard-mandatory forbids entirely.

B — Hard, soft, advisory

Correct. Never means hard-mandatory; a justified exception means soft-mandatory; encouraged but non-blocking means advisory.

C — Inverted

Reverses the strongest and weakest requirements, making a legal boundary overridable and a naming convention absolute.

D — All advisory plus a run task

Advisory never blocks, so the residency rule would be unenforced. A run task could gate it, and Sentinel already does this natively.

THE SIGNAL

The scenario states each level in plain English. 'Never', 'occasionally justified', 'must not block' map one to one.

> A team already uses check blocks to assert that TLS certificates in their configuration have more than thirty days until expiry. The assertions run whenever somebody plans, which for some workspaces is once a quarter.
>
> They want to be told about an approaching expiry without waiting for the next plan.

What should they enable?

A. Continuous validation, which re-runs check blocks on a schedule

B. A hard-mandatory Sentinel policy on certificate expiry

C. Auto-apply, so workspaces run more often

D. A scheduled pipeline running terraform plan -refresh-only

◆ PAUSE AND DECIDE

What should they enable?

A Continuous validation

Correct. It re-runs exactly the check blocks they already wrote, on a schedule, and surfaces the results on the workspace.

B A hard-mandatory policy

Would block every apply once a certificate neared expiry, turning an advance warning into an outage. Module twelve's scenario 1, restated.

C Auto-apply

Applies successful plans automatically. It does not cause runs to happen, and it removes a safety step for no benefit here.

D Scheduled refresh-only

A sound drift detector from M17, and refresh-only detects state versus reality. It does not evaluate check blocks.

THE SIGNAL

They already wrote the logic. Continuous validation runs the same check blocks more often, without changing what failure does.

> A defence contractor must run all infrastructure tooling inside an isolated network with no internet egress. Regulation requires that state data never leaves their own facilities. They want policy enforcement, run history, teams and a private module registry.
>
> An architect asks which Terraform offering fits.

What should be recommended?

A Community edition, since the paid features cannot work in an isolated network

B Terraform Enterprise, self-hosted inside their own infrastructure

C HCP Terraform with agents, which keeps state inside their network

D HCP Terraform with Local execution mode, so nothing leaves the network

◆ PAUSE AND DECIDE

What should be recommended?

A Community edition

Gives up all four things they asked for. Isolation is a deployment constraint, not a reason to abandon the requirements.

B Terraform Enterprise

Correct. Self-hosted delivers the same capabilities inside their own boundary, which is exactly what data residency and isolation require.

C HCP Terraform with agents

*Agents solve reachability of infrastructure. **State would still live in HashiCorp's service**, which the regulation forbids.*

D Local execution mode

Module twenty-one: it removes policy enforcement and variable evaluation, and state still lives in the service anyway.

THE SIGNAL

Agents move execution; they do not move state. The requirement here is about where data rests, not where runs happen.

> A platform team wants every storage bucket to have encryption enabled. A module author proposes adding a precondition to their shared module that fails if encryption is off. The platform team proposes a Sentinel policy instead.
>
> Both would catch the case described. The team asks which is right.

What is the correct reasoning?

A. The precondition, because it fails earlier and gives a clearer message

B. The policy, because a module author can remove a precondition and cannot remove a policy

C. Either. They are equivalent mechanisms with different syntax

D. The precondition, because Sentinel cannot inspect resource arguments

◆ PAUSE AND DECIDE

What is the correct reasoning?

A Precondition, earlier

Both true, and neither decides it. A clear early failure is worth having; it is not an enforcement guarantee.

B Policy, because it cannot be removed

Correct. The distinction is ownership: a condition lives in the code it checks; a policy is owned by another team and evaluated outside.

C Equivalent

They catch the same case and differ in who controls the rule, which is the entire point of governance.

D Sentinel cannot inspect arguments

False. Sentinel evaluates the plan, which contains the resource arguments. That is precisely what it is for.

THE SIGNAL

Not either-or in practice. The module gives a fast, clear failure; the policy guarantees the rule survives someone deciding otherwise.

Module 23 recap

- **Advisory warns. Soft-mandatory can be overridden. Hard-mandatory cannot.**
- **Sentinel is HashiCorp's; OPA is the open source alternative.** Both evaluate the plan.
- **Run tasks call an external service** and can fail the run.
- **Health assessments** cover drift detection and continuous validation. Never remediation.
- **Community edition has the language and no service.**
- **Terraform Enterprise is self-hosted**, for data residency and isolated networks.

> ON THE EXAM
>
> Governance is a rule the configuration author cannot remove. That single test separates policy from every condition in module twelve.